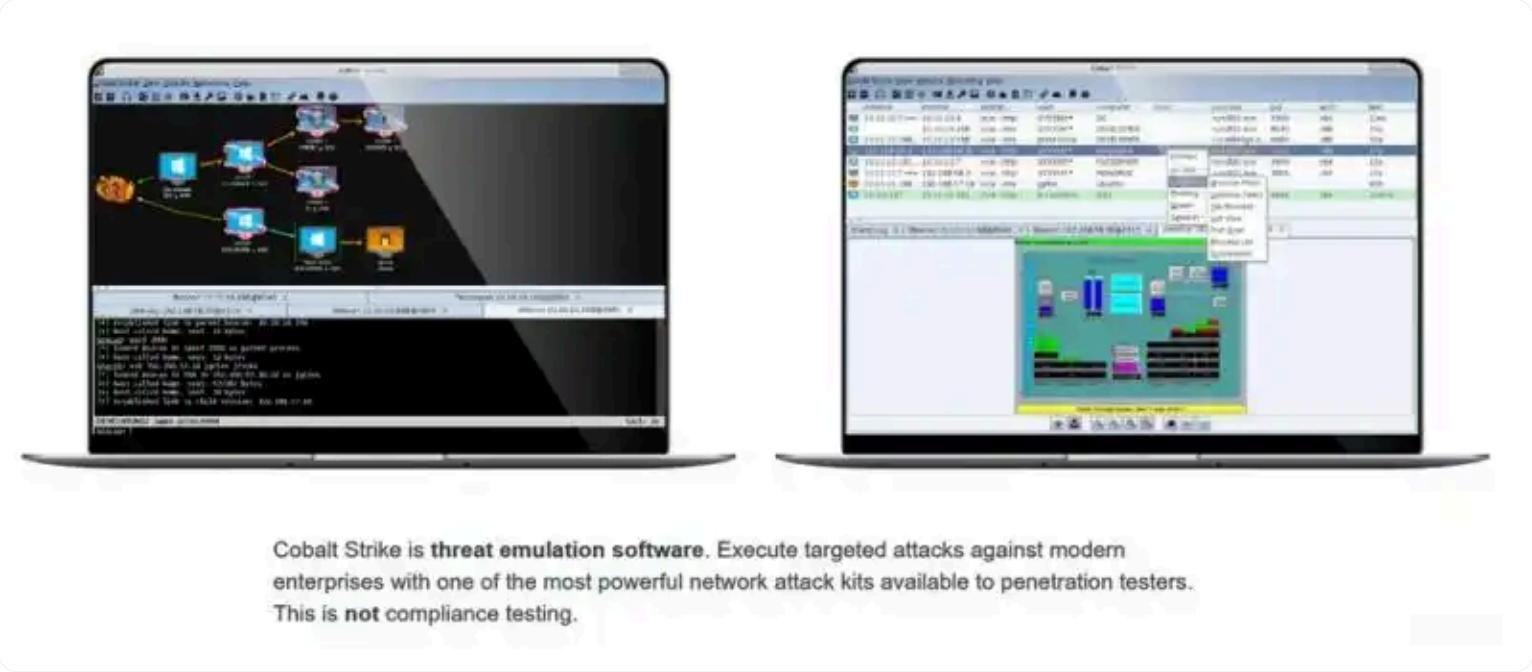
渗透测试工具Cobalt Strike存在DoS漏洞，可以用来遏制攻击行动

十轮网　2021-08-06 19:42



渗透测试工具Cobalt Strike是红队演练实用的工具之一，近年来也有越来越多的攻击者滥用这款工具，根据安全公司Proofpoint的统计，在2019年到2020年之间，滥用Cobalt Strike的攻击行动暴增161%。对此，如何阻止攻击者滥用该渗透测试工具的行为，也成为安全研究员研究的对象。安全企业SentinelOne发现在4.2与4.3版的Cobalt Strike里，存在名为Hotcobalt的拒绝服务（DoS）漏洞CVE-2021-36798，一旦安全人员运用这项漏洞，就可以阻拦攻击者远程控制受害目标的行为。

基本上，软件出现漏洞，通常是受害系统暴露遭受攻击的危险，但如今出现漏洞的是被攻击者滥用的渗透测试工具，也使得安全人员与执法单位能用来防堵网络攻击。

为了让安全人员更容易研究Cobalt Strike的Beacon通信机制，SentinelOne也提供了以Python打造的程序库，来协助他们解析其通信内容。

这项漏洞涉及Cobalt Strike服务器（也称为Teamserver）与Beacon之间的通信。SentinelOne解释其中的运行流程：一般来说，Teamserver第一次执行时，会随机产生公用与私有的RSA密钥，并存放于名为.Cobalt Strike.beacon_keys的文件，而每个Beacon信号发送器（Stager）都内置公用的密钥。

```
PS C:\code\CobaltStrikeParser> python .\parse_beacon_config.py https://[redacted] --json | bash -c jq *
{
  "BeaconType": [
    "HTTPS"
  ],
  "Port": 443,
  "SleepTime": 30000,
  "MaxGetSize": 1398102,
  "Jitter": 20,
  "MaxDNS": "Not Found",
  "PublicKey": "MIGfMA0GCSqGSIb3DQEBAQUAA4GNADCBiQKBgQCWs6Ncl4PW7dWXnXgXpN17O1WAjGW47NIF3aB+U6mZohik2BSgH
HTdyooDi5EuVLWm2X5W8vWDF6vsNhWb0bO/1ZPH3YKQWzX8OFrhWOXR0S1z/BQpL+h6xFPnNGfMlsXqpq4p2PeGQIDAQAB
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA==",
  "PublicKey_MD5": "9b733ab863602b7737678043e7454bb6",
  "C2Server": "[redacted]./owa/",
  "UserAgent": "Mozilla/5.0 (Windows NT 6.1) AppleWebkit/537.36 (KHTML, like Gecko)",
  "HttpPostUri": "/OWA/",
```

十轮网

当信号发送器在受害计算机执行时，会收集计算机信息，诸如中央处理器架构、键盘布局、内部IP地址等，并通过前述公钥加密并回传给Teamserver，发出HTTP GET请求向服务器注册。一旦注册成功之后，Beacon就能接收攻击者下达的指令并执行工作。

但SentinelOne指出，在执行Screenshot和Keylogger工作的回传结果中，服务器必须分配指定大小的缓冲区来容纳文件，对此，研究人员发现，可以借由控制发送的屏幕截屏文件大小，来让Cobalt Strike服务器分配特定容量的内存作为缓冲区，导致服务器的内存消耗殆尽。

利用这项漏洞，研究人员利用伪造的Beacon，向Teamserver发送假的任务资料，或是异常大的屏幕截屏，来占用Teamserver的内存空间，导致该服务器的内存耗尽而无法回应，造成拒绝服务的局面，换言之，这样的情况使得所有的Beacon无法与该服务器通信。

```
public void process_beacon_callback_decrypted(final String beaconID, final byte[] responseBytes) {
...
// Sanity checks here
...
try {
final DataInputStream responeBytesStream = new DataInputStream(new ByteArrayI
cmd = responeBytesStream.readInt();
if (cmd == 0) {...}
...
else if (cmd == 3) {
        final DataParser dp = new DataParser(CommonUtils.readAll(responeBytes
        dp.little();
        final byte[] scData = dp.readCountedBytes();      // Bug #1 here
        final int scDesktop = dp.readInt();
        final String scTitle = this.getCharsets().process(beaconID, dp.readCou
        final String process6 = this.getCharsets().process(beaconID, dp.readCo
        if (scData.length == 0) {
                output(BeaconOutput.Error(beaconID, "screenshot from desktop " +
                return;
        }
        ...
        output(BeaconOutput.OutputB(beaconID, "received screenshot of " + scTitle
        ...
}}}
```

十轮网

对此，SentinelOne指出，除非管理者将Teamserver重开机，才能暂时摆脱内存耗尽的情况，攻击者很可能再度发动攻击来瘫痪Cobalt Strike的运行。该公司也发布了概念性验证（PoC）攻击程序。

由于Cobalt Strike也被攻击者大肆滥用，执法单位与安全研究人员可能可以通过Hotcobalt漏洞，来关闭攻击者的基础设施。而对于这个漏洞的披露，SentinelOne于4月20日通报给HelpSystems，HelpSystems则于8月4日发布了Cobalt Strike 4.4进行修补。

举报/反馈